

DOCUMENTAZIONE TECNICA DI PROGETTO

EVoteChain

Piattaforma di Governance Decentralizzata



Report di Cybersecurity e Architettura Software

*Implementazione su Hyperledger Fabric per Consigli di
Amministrazione*

Autori:

Francesco Cosciotti

Christian Sfeir

Mario Chiappini

Data di Rilascio:

Dicembre 2025

Indice

1	Introduzione al Progetto	1
1.1	Panoramica Generale	1
1.2	Obiettivi del Sistema	1
1.3	Ambito di Applicazione	1
2	Analisi degli Attori e Requisiti	3
2.1	Classificazione degli Attori	3
2.1.1	Il CEO (Amministratore)	3
2.1.2	I Membri del Consiglio	3
2.2	Casi d'Uso (Use Cases)	4
2.2.1	Caso d'Uso: Creazione Riunione (CEO)	4
2.2.2	Caso d'Uso: Votazione (Membro)	4
3	Protocolli di Sicurezza e Autenticazione	5
3.1	Architettura di Sicurezza	5
3.2	Flusso di Autenticazione (Auth Flow)	5
3.2.1	Componenti della Verifica	5
3.2.2	Logica Decisionale (Algoritmo di Login)	5
4	Funzionalità e Workflow Dettagliati	7
4.1	Workflow Lato CEO	7
4.1.1	1. Crea Riunione	7
4.1.2	2. Start Voting	7
4.1.3	3. Chiusura Riunione e Consolidamento	7
4.1.4	4. Verifica Validità e Idoneità	8
4.2	Workflow Lato Membri	8
4.2.1	1. Gestione Inviti	8
4.2.2	2. Processo di Voto	8
5	Analisi delle Minacce (Threat Modeling)	9
5.1	Attacchi all'Autenticazione	9
5.1.1	Errore Login e Credential Stuffing	9
5.1.2	Accesso Geografico Impossibile (Impossible Travel)	9
5.2	Attacchi al Consenso e alla Rete	9
5.2.1	Attacco Replay (Double Voting)	9

5.2.2	Discrepanza Validazione Smart Contract	10
5.2.3	Tentativo di Modifica Dati Storici	10
5.2.4	Revoca Certificato MSP	10
5.3	Attacchi Infrastrutturali	10
5.3.1	Eclipse Attack	10
5.3.2	Attacco DoS / DDoS	10
5.3.3	Analisi Traffico Sospetta	11
6	Specifiche Tecniche dei Dati	12
6.1	Struttura del Ledger	12
6.1.1	Asset: Riunione	12
6.1.2	Asset: Voto	12
7	Conclusioni	13

Elenco delle tabelle

Elenco delle figure

Introduzione al Progetto

1.1 Panoramica Generale

Il progetto **EVoteChain** rappresenta una risposta tecnologica avanzata alle crescenti esigenze di sicurezza e trasparenza nei processi decisionali aziendali. Esso nasce con l'obiettivo primario di realizzare una piattaforma integrata *end-to-end* per la gestione digitale delle riunioni di un Consiglio di Amministrazione (CdA), ponendo particolare enfasi sulla protezione del dato, sulla tracciabilità delle operazioni e sull'immutabilità degli esiti.

In un contesto in cui la *corporate governance* richiede standard sempre più elevati, l'uso di sistemi tradizionali centralizzati espone le aziende a rischi di manipolazione, accessi non autorizzati e perdita di dati. EVoteChain mitiga questi rischi attraverso un'architettura decentralizzata.

1.2 Obiettivi del Sistema

Cuore del sistema è un meccanismo di *e-voting* progettato per garantire votazioni affidabili, anonime e a prova di manomissione. Tale risultato è ottenuto grazie all'impiego della tecnologia blockchain **Hyperledger Fabric**, un framework *permissioned* ideale per contesti enterprise.

Gli obiettivi specifici includono:

- **Sicurezza:** Protezione crittografica di ogni transazione e voto.
- **Trasparenza:** Verificabilità del processo di voto da parte degli aventi diritto (auditability).
- **Immutabilità:** Garanzia che, una volta registrato, un dato (verbale o voto) non possa essere alterato retroattivamente.
- **Efficienza:** Automazione della gestione delle riunioni da parte del Presidente (CEO).

1.3 Ambito di Applicazione

La piattaforma consente al Presidente del Consiglio di Amministrazione di organizzare e gestire in modo efficiente le riunioni, definendo gli ordini del giorno, avviando

sessioni di voto e supervisionandone l'andamento in tempo reale. Per ogni riunione è inoltre possibile registrare e conservare sulla blockchain la relativa documentazione, inclusi ordine del giorno e verbale, assicurandone così la tracciabilità e l'immutabilità nel tempo.

Attraverso l'adozione di *Smart Contract* (Chaincode) dedicati, EVoteChain offre un ambiente affidabile che tutela l'anonimato dei votanti, elimina la possibilità di alterazione dei dati e fornisce un archivio permanente. Il risultato è un sistema moderno, robusto e conforme alle esigenze di governance aziendale, in grado di migliorare il processo decisionale e ampliare il livello di sicurezza delle procedure interne.

Analisi degli Attori e Requisiti

2.1 Classificazione degli Attori

Il sistema EVoteChain prevede un modello di controllo degli accessi (ACL) basato sui ruoli. Gli attori interagiscono con la blockchain attraverso interfacce dedicate che filtrano le operazioni consentite.

2.1.1 Il CEO (Amministratore)

Il CEO rappresenta l'autorità massima all'interno della sessione di voto. Non influenza il voto degli altri, ma gestisce l'infrastruttura logica della riunione.

Responsabilità: • Creazione dell'indice di riunione giornaliero.

- Definizione di data, ora, luogo e lista dei partecipanti autorizzati.
- Pubblicazione dell'Ordine del Giorno (OdG).
- Gestione attiva della votazione (Apertura e Chiusura seggi).
- Controllo e verifica dell'idoneità dei votanti (tramite MSP).
- Chiusura formale della riunione e commit dei dati.

2.1.2 I Membri del Consiglio

I membri sono i partecipanti attivi alla riunione. Ogni membro è identificato univocamente e possiede un attributo di "Ruolo Aziendale" (un valore intero tra 1 e 5) che ne determina il peso o la categoria gerarchica.

Sottocategorie di Membri: • **Votante SI (Active Member):** Membro con pieni diritti di voto. Può esprimere preferenze vincolanti.

- **Votante NO (Guest/Auditor):** Membro che partecipa alla riunione con diritti di sola visualizzazione. Non possiede token di voto e funge da osservatore (es. consulenti esterni, segretari verbalizzanti).

Dati del Membro: Ogni transazione generata da un membro porta con sé i metadati: Nome, Cognome, Categoria (1-5), Timestamp e Firma Digitale.

2.2 Casi d'Uso (Use Cases)

2.2.1 Caso d'Uso: Creazione Riunione (CEO)

Attore Primario: CEO

Pre-condizione: Login effettuato con successo.

Flusso:

1. Il CEO accede alla sezione "Nuova Riunione".
2. Inserisce i metadati: Data, Ora, Luogo.
3. Seleziona i membri partecipanti dalla lista certificata.
4. Definisce i punti all'Ordine del Giorno.
5. Il sistema genera un **MeetingID** univoco e lo scrive sul ledger.

2.2.2 Caso d'Uso: Votazione (Membro)

Attore Primario: Membro (Votante SI)

Pre-condizione: Riunione in stato "OPEN" e Membro autenticato. **Flusso:**

1. Il membro riceve notifica di voto aperto.
2. Seleziona la propria preferenza per il punto all'OdG corrente.
3. Il sistema verifica che il membro non abbia già votato (check *double spending*).
4. Il voto viene crittografato e inviato come transazione.

Protocolli di Sicurezza e Autenticazione

3.1 Architettura di Sicurezza

La sicurezza in EVoteChain non è un componente aggiuntivo, ma è integrata in ogni livello, dall'autenticazione utente alla persistenza del dato su Blockchain.

3.2 Flusso di Autenticazione (Auth Flow)

L'accesso alla piattaforma è governato da un rigoroso protocollo multi-fattore. Il sistema distingue nettamente tra un tentativo di accesso legittimo e uno potenzialmente malevolo.

3.2.1 Componenti della Verifica

Il modulo **Auth** esegue controlli sequenziali su:

1. **ID e Password:** Verifica base delle credenziali crittografate (Hash).
2. **Verifica Device:** Controllo dell'indirizzo IP e del MAC Address per garantire che l'accesso avvenga da dispositivi censiti o reti sicure.
3. **Verifica a due fattori (2FA):** Invio di un token temporaneo via Email e/o Cellulare.

3.2.2 Logica Decisionale (Algoritmo di Login)

Il sistema opera secondo una logica binaria rigorosa per proteggere il ledger.

Algorithm 1: Algoritmo di Gestione Accessi EVoteChain

Result: Accesso o Blocco

```

1 Input: UserCreds, DeviceFingerprint, GeoData;
2 Output: SessionToken o SecurityAlert;
3 Inizio Procedura Auth;
4 if Credenziali == Valide then
5     Check IP e MAC Address;
6     Check Geo-Location (No Impossible Travel);
7     Richiedi 2FA Token;
8     if 2FA == Corretto then
9         CASO 1: LOGIN TRUE (Consentito);
10        Generazione Certificato di Sessione;
11        Retrieve Ruolo Utente (CEO o Membro);
12        Redirect verso Dashboard specifica (PaginaID);
13    else
14        CASO 2: LOGIN FALSE (Rifiutato);
15        Trigger Errore: "Autenticazione Fallita";
16    end
17 end
18 else
19     CASO 2: LOGIN FALSE (Rifiutato);
20 end
21 if Esito == FALSE then
22     /* Protocollo di Difesa Attiva */
23     1. Chiudere immediatamente la connessione Socket con la Blockchain;
24     2. Revocare eventuali token temporanei;
25     3. Inviare Email di Alert al Security Operation Center (SOC);
26     4. Loggare l'evento (IP, Timestamp) in una lista di "Sospetti";
27 end

```

Funzionalità e Workflow Dettagliati

4.1 Workflow Lato CEO

Una volta autenticato come CEO, l'utente viene indirizzato alla **Pagina Amministratore**. Le azioni possibili sono sequenziali e vincolanti per il sistema.

4.1.1 1. Crea Riunione

Questa funzione accetta in input le credenziali della riunione.

- **Input:** Data, Ora, Topic Principale, Lista Punti OdG, Lista Partecipanti (Public Keys).
- **Elaborazione:** Lo Smart Contract verifica la disponibilità delle risorse e crea un asset "Meeting" nello stato *Pending*.
- **Output:** Restituzione dell'`ID_Riunione` e calcolo automatico della scadenza riunione (Timeout).

4.1.2 2. Start Voting

Funzione *real-time* critica.

- Il CEO abilita la ricezione dei voti per un punto specifico.
- Il sistema inizia a raccogliere i **Token Vote (Coin)**. Ogni membro avente diritto possiede un "coin" spendibile per quella votazione.
- **Salvataggio Real-time:** I risultati parziali vengono salvati provvisoriamente nel world state della blockchain.
- **Chiusura Automatica:** Allo scadere del tempo (variabile configurabile `Time_Limit`), il sistema chiude i seggi, rifiutando ulteriori transazioni.

4.1.3 3. Chiusura Riunione e Consolidamento

Al termine dei lavori, il CEO invoca la chiusura.

- **Logout Massivo:** Il sistema forza il logout di tutti i membri partecipanti per sicurezza.

- **Final Commit:** Viene generato un blocco contenente: ID_Riunione + Output Votazione (diviso per OdG). Questo blocco viene aggiunto all'ultimo nodo della blockchain, rendendo i dati perenni.

4.1.4 4. Verifica Validità e Idoneità

Processo di background che verifica costantemente che i certificati utilizzati per la votazione siano validi e conformi alle policy MSP (Membership Service Provider) definite nel canale Hyperledger.

4.2 Workflow Lato Membri

Il membro autenticato accede alla **Pagina Membri**.

4.2.1 1. Gestione Inviti

All'accesso, un sistema di notifica (Pop-up Front End) informa di eventuali riunioni attive.

- **Button "Accetta":** Il membro firma digitalmente la presenza. Il sistema lo reindirizza alla pagina specifica ID_Riunione.
- **Button "Rifiuta":** L'utente rimane nella dashboard, non viene conteggiato nel quorum.

4.2.2 2. Processo di Voto

Nella pagina della riunione, se lo stato è "VOTING_OPEN":

- Il membro visualizza le opzioni (Sì/No/Astensione).
- Selezionando l'opzione, invia il proprio "Token Vote".
- **Feedback:** Il sistema conferma l'avvenuta transazione (TxID).

Analisi delle Minacce (Threat Modeling)

In questo capitolo vengono analizzati nel dettaglio i vettori di attacco identificati e le relative contromisure implementate in EVoteChain.

5.1 Attacchi all'Autenticazione

5.1.1 Errore Login e Credential Stuffing

Minaccia: Tentativi automatizzati di indovinare le credenziali o uso di credenziali rubate da altri servizi (Stuffing). **Mitigazione:** Il sistema implementa un blocco esponenziale dopo N tentativi falliti. L'uso obbligatorio della 2FA rende inefficace il solo possesso della password. In caso di errore login critico, la connessione alla blockchain viene troncata a livello di socket.

5.1.2 Accesso Geografico Impossibile (Impossible Travel)

Minaccia: Due login validi avvengono per lo stesso utente da luoghi fisici distanti in un tempo troppo breve (es. Milano e Tokyo in 5 minuti). **Mitigazione:** Il modulo di sicurezza calcola la velocità di spostamento necessaria. Se $> 1000km/h$, l'accesso viene flaggato come compromesso e bloccato.

5.2 Attacchi al Consenso e alla Rete

5.2.1 Attacco Replay (Double Voting)

Minaccia: Un attaccante intercetta il pacchetto dati contenente il "Voto Sì" di un utente e lo reinvia più volte per alterare il conteggio. **Mitigazione:**

1. **Nonce:** Ogni transazione include un numero casuale (nonce) usato una sola volta.
2. **Controllo di Stato:** Lo Smart Contract verifica se il `WalletID` ha già speso il token per quel `ProposalID`. Se sì, la transazione è rigettata.

5.2.2 Discrepanza Validazione Smart Contract

Minaccia: Un nodo malevolo tenta di proporre un blocco con risultati di voto calcolati erroneamente. **Mitigazione:** Hyperledger Fabric utilizza una *Endorsement Policy*. La transazione deve essere firmata da un numero minimo di peer validatori. Se i risultati non coincidono (discrepanza), il blocco viene scartato dall'Orderer Service.

5.2.3 Tentativo di Modifica Dati Storici

Minaccia: Un amministratore corrotto tenta di cambiare il verbale di una riunione passata. **Mitigazione:** La struttura a catena di blocchi (Blockchain) rende questo impossibile. Ogni blocco contiene l'hash del precedente. Modificare un blocco richiederebbe la rigenerazione di tutti i blocchi successivi e il consenso della rete, scenario irrealizzabile.

5.2.4 Revoca Certificato MSP

Minaccia: Un membro licenziato (il cui certificato è ancora matematicamente valido) tenta di accedere. **Mitigazione:** Il sistema consulta in tempo reale la CRL (Certificate Revocation List) gestita dalla CA aziendale prima di autorizzare qualsiasi transazione.

5.3 Attacchi Infrastrutturali

5.3.1 Eclipse Attack

Minaccia: L'attaccante controlla tutte le connessioni in entrata e uscita di un nodo, isolandolo dalla rete onesta e fornendogli dati falsi. **Mitigazione:** EVoteChain mantiene una lista statica di peer affidabili e utilizza canali cifrati TLS mutualmente autenticati, rendendo impossibile per un attaccante inserirsi nel mezzo senza i certificati root.

5.3.2 Attacco DoS / DDoS

Minaccia: Saturazione delle risorse per bloccare la votazione. **Mitigazione:** Rate limiting sugli API Gateway e architettura distribuita: anche se un nodo cade, gli altri garantiscono la continuità del servizio.

5.3.3 Analisi Traffico Sospetta

Minaccia: Deduzione del voto basata sulla dimensione dei pacchetti crittografati o sulle tempistiche. **Mitigazione:** Tecniche di *Traffic Padding* (uniformare la dimensione dei pacchetti) e invio di transazioni dummy per offuscare i pattern reali.

Specifiche Tecniche dei Dati

6.1 Struttura del Ledger

I dati su Hyperledger Fabric sono memorizzati come coppie Chiave-Valore. Di seguito la specifica JSON degli asset principali.

6.1.1 Asset: Riunione

Questo asset viene creato all'inizializzazione.

```
{
  "docType": "meeting",
  "meetingId": "MTG_2025_12_01_A",
  "timestamp": "2025-12-01T09:00:00Z",
  "organizer": "CEO_User_ID",
  "participants": {
    "total": 12,
    "quorum_reached": true,
    "list": ["UserHash1", "UserHash2", ...]
  },
  "status": "CLOSED"
}
```

6.1.2 Asset: Voto

Per garantire l'anonimato ma consentire la verifica, l'ID votante è sottoposto a hashing.

```
{
  "docType": "vote",
  "voteId": "VT_77382910",
  "meetingRef": "MTG_2025_12_01_A",
  "agendaItem": 1,
  "voterRole": 3,
  "encryptedChoice": "SHA256(...)",
  "timestamp": "2025-12-01T10:15:30Z"
}
```

Conclusioni

Il progetto EVoteChain dimostra come l'applicazione della tecnologia Blockchain ai processi di governance aziendale non sia solo un esercizio teorico, ma una necessità pratica per garantire sicurezza e conformità.

Attraverso l'implementazione dettagliata dei flussi di autenticazione e l'analisi approfondita delle minacce (dal Replay Attack all'Eclipse Attack), la piattaforma offre un baluardo contro le vulnerabilità informatiche moderne. La separazione dei ruoli, l'immutabilità del registro distribuito e l'automazione degli Smart Contract rendono EVoteChain una soluzione pronta per l'adozione in contesti critici.